

STOQUIFY

Agent Runtime Phase 2A Guardrail & Enterprise Gate Rerun

Skills 016 and 017 | Engineering assurance and release decision

APPROVED WITH REQUIRED FIXES

Engineering baseline approved. Internal activation remains blocked.

Report date 22 July 2026	PDF issued 23 July 2026	Classification Internal engineering
------------------------------------	-----------------------------------	---

Date: 2026-07-22

Skills executed in order:

1. 016-aqstoqflow-ai-copilot-guardrails
2. 017-aqstoqflow-enterprise-release-gate

Final decision: APPROVED WITH REQUIRED FIXES

Engineering baseline: **Approved**

Internal activation: Blocked

Executive Decision

The Phase 2A deterministic Command Agent now satisfies the technical guardrail baseline for a read-only, evidence-backed internal pilot candidate. It remains provider-free, cannot perform business writes, derives tenant and actor identity from trusted server context, applies RBAC and module controls, preserves source evidence and redaction disclosures, and fails closed through a default-off rollout plus kill switch.

The first release review's technical High finding and most Medium findings are closed. Internal activation is still blocked because product/security approval, named rollout and rollback owners, an actual production scheduler deployment, operator alert ownership, and enabled-path browser evidence are not recorded. Definitions remain DRAFT; no activation command was run.

Skill 016 Result

Selected skill: 016-aqstoqflow-ai-copilot-guardrails

Status: **Passed for the implemented Phase 2A boundary**

Closed controls:

- Governed agent definition, skill key/version, and prompt hash are written in the initial AgentRun insert.
- Tool execution has a bounded 1-30 second server timeout and persists AGENT_TIMEOUT without exposing private tool errors.
- Concurrent same-scope correlation races recover the scoped run receipt; cross-scope conflicts do not enumerate another run.
- Correlation uniqueness is tenant, actor, and agent scoped rather than global.
- Duration, tool, evidence, redaction, failure, and stale-output state are durable on AgentRun; the logger is supplemental.

- Abandoned runs can be reconciled through a fail-closed internal endpoint protected by a minimum 32-character constant-time bearer check.
- Authenticated desktop and mobile tests prove the kill switch leaves the Command Agent visible, explanatory, disabled, and free of horizontal overflow.
- The tool registry and prohibited-action gates confirm the runtime remains read-only and provider-free.

Skill 017 Findings

High: Activation Governance Is Not Recorded

No signed product owner or security approval, pilot organization decision, rollout owner, rollback owner, support owner, or activation window is present. The design freeze correctly states that it is an engineering baseline pending approval.

Required before activation: record the approvers, approved organization and roles, owner contacts, activation window, rollback decision authority, and acceptance of the residual Medium items below.

Medium: Reconciliation Is Callable But Not Scheduled

POST /api/internal/agents/reconcile-abandoned is authenticated, bounded, correlated, and invokes the canonical reconciler. No deployment scheduler, configured secret evidence, cadence monitor, or named operations owner is recorded.

Required before activation: deploy the endpoint secret, schedule it at an approved cadence, alert when execution is late or fails, and record the owner and rollback procedure.

Medium: Operator Alerts Are Not Yet Operational

Per-run latency, counters, stale state, failure code, policy incidents, and feedback are durable in PostgreSQL. The generic logger has no default production sink, and no Command Agent alert rule or operator dashboard ownership is recorded.

Required before activation: wire the existing logging/metrics transport in the target environment and define thresholds and owners for repeated policy denials, timeout rate, abandoned runs, unsafe feedback, correction rate, and stale-output rate.

Medium: Enabled Pilot Browser Coverage Is Pending

Authenticated desktop and mobile kill-switch coverage passes. Unit/component tests cover allowed, denied, shadow, stale, evidence, feedback, and typed failure behavior. The real `internal` enabled path remains intentionally unavailable because definitions are still `DRAFT` and no pilot is approved.

Required before activation: provision the approved manifest in a non-production pilot environment, exercise the enabled brief, evidence navigation, keyboard path, stale/partial behavior, feedback, entitlement denial, timeout, and kill-switch rollback in Playwright.

Low: Evidence Drill-Through Remains Route-Based

Priorities include protected source routes and evidence IDs, but there is no subject-specific proof drawer in the Command Agent panel. Protected source navigation is acceptable for this deterministic pilot baseline; a proof drawer should follow only after subject-level permission validation is reusable.

Findings Closed Since The First 017 Pass

Previous finding	Resolution
Initial provenance could be missing after a crash	Definition and skill provenance now persist in the initial run insert
Concurrent replay could return raw P2002	Same-scope conflict recovery returns the scoped receipt; cross-scope remains non-enumerating
No execution timeout	Bounded timeout with typed AGENT_TIMEOUT and safe summaries
No reconciliation entry point	Authenticated, bounded internal reconciliation route added
Metrics depended on a no-op logger	Operational run metrics and stale state persist on AgentRun
No authenticated desktop/mobile coverage	Kill-switch release test passes on Desktop Chrome and Pixel 7
Correlation uniqueness crossed tenant boundaries	Composite tenant/actor/agent/correlation uniqueness deployed and smoke-tested

Enterprise Gate Matrix

Gate	Decision	Evidence
Architecture and context	Passed	Reuses canonical agent, Daily Digest, module, evidence, action, and graph-visible service boundaries
Tenant scope	Passed	Trusted context, scoped reads/updates, composite correlation uniqueness, PostgreSQL cross-tenant and same-scope tests
RBAC and module control	Passed	dashboard.read, protected actions, module entitlement, role filtering, default-off rollout
Ledger/event integrity	Passed / not applicable	No ledger, stock, payment, payroll, close, filing, certification, approval, or permission mutation
Idempotency	Passed	Scoped lookup, database uniqueness, race recovery unit test, PostgreSQL P2002 proof
Error safety	Passed	Typed action errors, timeout code, safe summaries, no raw tool error exposure
Notifications	Conditional	User-visible states and policy incidents exist; operator alert transport/owner pending
UX completeness	Conditional	Desktop/mobile kill-switch passes; enabled pilot browser matrix pending approval
Evidence and redaction	Passed	Every priority is evidence-linked or limited; redaction and stale disclosures are validated
Observability	Conditional	Durable run metrics and correlation IDs pass; production alert sink and ownership pending
Database	Passed	30 migrations current; both PostgreSQL smoke suites pass with zero residual runtime-smoke rows
Verification	Passed	TypeScript, ESLint, 17 suites/46 tests, static gates, boundary, assurance, trust, browser, and diff checks pass

Verification Evidence

- Prisma schema valid.
- Migration safety: 8/8 checks ready, zero risk findings, zero blockers.
- Migrations 20260722161000_agent_runtime_phase_2a_operational_controls and 20260722162000_agent_runtime_tenant_scoped_correlation deployed.
- PostgreSQL reports 30 migrations and an up-to-date schema.
- Agent runtime smoke passed tenant-scoped reads, cross-tenant foreign-key denials, cross-tenant correlation reuse, same-scope duplicate rejection, and cleanup with zero residual rows.
- Phase 2A smoke passed feedback uniqueness, cross-tenant rejection, and provenance round trip.
- Full TypeScript check passed.
- Focused ESLint passed.
- Agent/UI Jest: 17 suites and 46 tests passed.
- Phase 2A, tool registry, prohibited action, and service-boundary gates passed; active service-boundary violations: 0.
- Workflow Assurance runtime: 7/7 tables and 3/3 migration rows present.
- Workflow Assurance release: 37/37 checks, 11/11 indexes, and 2/2 engine-health gates ready.
- Report Trust: 9/9 checks ready.
- Authenticated Playwright: desktop and mobile kill-switch tests passed on isolated port 3101.
- `git diff --check` passed; line-ending warnings are informational.

Environmental note: normal Prisma generation updates the client to `engineType: library` but Windows refuses to rename an identical locked query-engine DLL (EPERM). The existing engine is the same Prisma version, and both live PostgreSQL smoke suites pass. This is a workstation lock issue, not a schema or runtime failure.

Files Changed In The Rerun

- `services/agents/agent-execution-control.service.ts`
- `services/agents/agent-runner.service.ts`
- `services/agents/command-agent.service.ts`
- `services/agents/agent-run-governance.service.ts`
- `services/agents/agent-reconciler-auth.service.ts`
- `actions/agents/command-agent.actions.ts`
- `app/api/internal/agents/reconcile-abandoned/route.ts`
- `prisma/schema.prisma`
- `prisma/migrations/20260722161000_agent_runtime_phase_2a_operational_controls/migration.sql`
- `prisma/migrations/20260722162000_agent_runtime_tenant_scoped_correlation/migration.sql`
- focused agent tests, Phase 2A gates/smokes, Playwright config/spec, and package scripts
- this rerun report

Unrelated pre-existing worktree changes, including components/landing/connected-workflow.tsx, were not modified or reverted by this rerun.

Promotion Rule

Keep definitions DRAFT, rollout off, and the kill switch available. Do not run provisioning with --activate and do not set production rollout to internal until the High finding is closed and a release owner explicitly accepts or closes every Medium finding.

Output Contract

Selected skills: 016-aqstoqflow-ai-copilot-guardrails, then 017-aqstoqflow-enterprise-release-gate

Gates passed: architecture, tenant, RBAC, module, read-only integrity, idempotency, typed errors, evidence, redaction, schema, migration, PostgreSQL, TypeScript, ESLint, Jest, service boundary, workflow assurance, report trust, desktop/mobile kill switch, and diff integrity.

Gates blocked: internal activation governance, deployed reconciler schedule/owner, production alert sink/owner, and enabled-pilot browser certification.

Verification result: APPROVED WITH REQUIRED FIXES as a technical engineering baseline; not approved for internal activation.

Next recommended numbered skill: remain on 017-aqstoqflow-enterprise-release-gate until the activation package is signed and the operational Medium gates are evidenced. Do not advance to model-backed Phase 2B.